SIMATS ENGINEERING

CSA6303- Threat Intelligence and Network Security

A1-Threat Intelligence Report

Assessment Questions

Subject	Threat Intelligence	**Total Marks**	50
Questions	10 (all compulsory)	**Marks per Question**	5
REg.No	192465008	**Name**	S.TANISHA
Faculty	Dr.V.Parthipan	**Slot**	A

Instructions: Answer all questions. Each question carries 5 marks. Support answers with examples and diagrams where appropriate.

Code of Conduct:

I _S.TANISHA (192465008)__ (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of Student : S.TANISHA

Questions

Q1. Malware [5 Marks]

Define malware and explain any four types of malware (virus, worm, trojan, ransomware, spyware). For each type, state how it spreads and one impact on the victim.

Q2. Phishing [5 Marks]

Describe how a phishing attack is carried out. Differentiate between spear phishing, whaling and vishing, and list three measures an organisation can adopt to reduce phishing risk.

Q3. DoS and DDoS [5 Marks]

Distinguish between a Denial of Service (DoS) attack and a Distributed Denial of Service (DDoS) attack. Explain the working of a SYN flood and outline two mitigation techniques.

Q4. Man-in-the-Middle Attacks [5 Marks]

What is a Man-in-the-Middle (MITM) attack? Explain two techniques used to carry it out (for example ARP poisoning, rogue Wi-Fi access point, SSL stripping) and state how encryption helps defend against it.

Q5. Spoofing and Sniffing [5 Marks]

Compare spoofing and sniffing. Explain IP spoofing and ARP spoofing with an example each, and describe how packet sniffers such as Wireshark can be used both maliciously and legitimately.

Q6. Vulnerability Assessment [5 Marks]

Explain the vulnerability assessment process. Describe its main phases, and differentiate between vulnerability assessment and penetration testing. Name two commonly used scanning tools.

Q7. Vulnerability Scoring [5 Marks]

What are CVE and CVSS? Explain how CVSS scores help in prioritising vulnerabilities and why a high CVSS score alone may not decide the order of patching.

Q8. Threat Data Sources and OSINT [5 Marks]

Discuss the main sources of threat data (internal, external, open-source and commercial). Define Open-Source Intelligence (OSINT) and describe three OSINT sources or tools used in threat intelligence gathering.

Q9. Indicators of Compromise (IoCs) [5 Marks]

What are Indicators of Compromise (IoCs)? Classify them into network-based, host-based and file-based indicators with two examples of each, and explain how a security team uses IoCs during incident response.

Q10. Threat Feeds [5 Marks]

Explain what a threat intelligence feed is. Describe the common feed formats and sharing standards (STIX/TAXII), list two advantages and two limitations of using threat feeds, and name two example feeds.

Marking Scheme (for evaluator)

Q.No	Expected points and mark distribution (total 5)
1	Definition (1); four types with spread method and impact (4 x 1 = 4).
2	Attack flow (1.5); three variants differentiated (1.5); three countermeasures (2).
3	DoS vs DDoS (1.5); SYN flood working (1.5); two mitigations such as rate limiting, SYN cookies, CDN/scrubbing, blackhole routing (2).
4	Definition and interception concept (1); two techniques (2); defences such as TLS, HSTS, certificate validation, VPN (2).
5	Comparison (1); IP and ARP spoofing with examples (2); sniffer dual use (1.5); one countermeasure (0.5).
6	Phases: asset discovery, scanning, analysis and prioritisation, reporting, remediation (2); VA vs pen test (2); two tools such as Nessus, OpenVAS, Qualys (1).
7	CVE meaning (1); CVSS meaning and severity ratings (1.5); role in prioritisation (1.5); context factors such as exploitability and asset criticality (1).
8	Threat data source categories (2); OSINT definition (1); three OSINT sources or tools such as Shodan, VirusTotal, WHOIS, social media, dark web monitoring (2).
9	Definition (1); classification with examples (3); use in detection and response (1).

Q.No	Expected points and mark distribution (total 5)
10	Definition (1); STIX/TAXII or similar formats (1.5); two advantages and two limitations (2); two example feeds such as AlienVault OTX, MISP, abuse.ch (0.5).

ANSWERS

Cybersecurity – Important 5-Mark Questions and Answers

Q1. Malware (5 Marks)

Definition: Malware (Malicious Software) is software designed to damage systems, steal information, disrupt operations, or gain unauthorised access.

Four Types of Malware

Type	Explanation	How It Spreads	Impact
1. Virus	Malicious code that attaches itself to a file or program.	Infected files, USB drives, and email attachments.	Corrupts or deletes files.
2. Worm	Malware that can replicate and spread automatically.	Spreads through networks by exploiting vulnerabilities.	Slows down networks and consumes system resources.
3. Trojan	Malware disguised as legitimate software.	Users download and install fake or infected applications.	Steals sensitive information or provides unauthorised access.
4. Ransomware	Malware that encrypts files and demands payment.	Phishing emails, malicious downloads, or exploited vulnerabilities.	Makes files inaccessible and causes financial loss.

Conclusion: Malware can be prevented using antivirus software, regular updates, firewalls, and safe browsing practices.

Q2. Phishing (5 Marks)

Definition: Phishing is a cyberattack in which attackers impersonate trusted individuals or organisations to steal sensitive information, such as passwords and banking details.

How a Phishing Attack Works

1. **Preparation:** The attacker creates a fake email, message, or website.
2. **Delivery:** The attacker sends the message to the victim.
3. **Deception:** The message may create urgency or promise a reward.
4. **Victim Action:** The victim clicks a malicious link or opens an attachment.
5. **Information Theft:** The attacker steals credentials or installs malware.

Types of Phishing

Type	Explanation	Example
Spear Phishing	Targets a specific person or organisation using personalised information.	A fake email sent to an employee mentioning their department.
Whaling	Targets senior executives or other high-profile individuals.	A fake payment request sent to a company's CEO.
Vishing	Uses voice calls to deceive victims.	A caller pretends to be a bank employee and asks for an OTP.

Three Measures to Reduce Phishing Risk

1. **Security Awareness Training:** Teach employees to identify suspicious messages.
2. **Multi-Factor Authentication (MFA):** Add another verification step to protect accounts.
3. **Email Security Filters:** Detect and block suspicious emails and malicious links.

Conclusion: Employee awareness, email filtering, and MFA help reduce phishing attacks.

Q3. DoS and DDoS (5 Marks)

Definition: A Denial of Service (DoS) attack attempts to make a system or service unavailable by overwhelming it with traffic or requests.

Difference Between DoS and DDoS

DoS	DDoS
Usually originates from a single system.	Originates from multiple systems.
Easier to identify the attack source.	More difficult to identify and block all sources.
Usually has a smaller attack capacity.	Can generate a much larger volume of traffic.
Can be mitigated by blocking the source in some cases.	Often requires distributed filtering and specialised protection.

Working of a SYN Flood Attack

A SYN flood exploits the TCP connection establishment process.

1. The attacker sends many TCP SYN requests to a server.
2. The server responds with SYN-ACK messages.
3. The attacker does not complete the TCP handshake by sending the final ACK.
4. The server keeps incomplete connections open.
5. The server's connection resources become exhausted, preventing legitimate users from connecting.

Flow:

Attacker → Multiple SYN Requests → Server Creates Pending Connections → Resources Exhausted → Service Disruption

Two Mitigation Techniques

1. **SYN Cookies:** Help protect the server against exhaustion of resources from incomplete TCP connections.
2. **Firewall and DDoS Protection:** Filter suspicious traffic and use rate limiting to reduce malicious requests.

Conclusion: DoS and DDoS attacks affect service availability. Traffic filtering and SYN flood protection help defend against them.

Q4. Man-in-the-Middle (MITM) Attacks (5 Marks)

Definition: A Man-in-the-Middle (MITM) attack occurs when an attacker secretly intercepts or manipulates communication between two parties.

Two Techniques Used in MITM Attacks

1. ARP Poisoning

- ARP poisoning occurs when an attacker sends forged Address Resolution Protocol (ARP) messages on a local network.
- The victim may associate the attacker's MAC address with the gateway's IP address.
- The attacker's system can then intercept traffic intended for the gateway.

Example: An attacker on a local network intercepts a victim's network traffic by impersonating the router.

2. Rogue Wi-Fi Access Point

- An attacker creates a fake Wi-Fi access point that resembles a legitimate network.
- A victim connects to the fake network.
- The attacker may monitor or manipulate unencrypted traffic passing through it.

Example: A fake public Wi-Fi network is created with a name similar to that of a café's genuine Wi-Fi network.

How Encryption Helps Prevent MITM Attacks

1. **HTTPS/TLS:** Encrypts communication between the browser and the website.
2. **Certificate Validation:** Helps users verify that they are communicating with the intended website.

3. **VPN:** Encrypts network traffic between the user's device and the VPN endpoint.

Conclusion: Encryption, certificate validation, and secure network connections help prevent attackers from reading or modifying communications.

Q5. Spoofing and Sniffing (5 Marks)

Spoofing: Spoofing is a technique in which an attacker falsifies information to impersonate a trusted device or source.

Sniffing: Sniffing is the process of capturing and examining network packets travelling across a network.

Difference Between Spoofing and Sniffing

Spoofing	Sniffing
Involves falsifying an identity or address.	Involves capturing network traffic.
Used to impersonate a trusted source.	Used to observe and analyse communication.
Can be used to redirect traffic or bypass weak trust mechanisms.	Can expose sensitive data if traffic is unencrypted.
Example: IP spoofing.	Example: Capturing network packets.

Types of Spoofing

1. IP Spoofing

IP spoofing occurs when an attacker forges the source IP address in network packets.

Example: An attacker sends packets with a forged source IP address to make traffic appear to originate from another system.

2. ARP Spoofing

ARP spoofing occurs when an attacker sends false ARP messages to associate an IP address with an incorrect MAC address.

Example: An attacker impersonates the network gateway on a local network to intercept traffic.

Packet Sniffers: Wireshark

Wireshark is a network protocol analyser used to capture and inspect network packets.

Malicious Uses:

- Capturing unencrypted passwords or sensitive information.
- Monitoring network communications without permission.
- Collecting information about network devices and services.

Legitimate Uses:

- Troubleshooting network problems.
- Analysing network performance.
- Investigating suspicious traffic and security incidents.

Conclusion: Spoofing falsifies network information, while sniffing captures traffic. Tools such as Wireshark are useful for authorised monitoring and security analysis.

Q6. Vulnerability Assessment (5 Marks)

Definition: Vulnerability assessment is the systematic process of identifying, analysing, and prioritising security weaknesses in systems, networks, and applications.

Main Phases of Vulnerability Assessment

1. **Planning and Scope Definition:** Identify the systems and networks to be assessed and obtain authorisation.
2. **Information Gathering:** Collect information about operating systems, applications, and network services.
3. **Vulnerability Scanning:** Use scanning tools to identify potential security weaknesses.
4. **Analysis and Risk Assessment:** Verify findings where possible and classify vulnerabilities according to their risk.

5. **Reporting and Remediation:** Prepare a report containing identified vulnerabilities, severity levels, and recommendations.
6. **Reassessment:** Scan again to confirm that vulnerabilities have been fixed.

Vulnerability Assessment vs Penetration Testing

Vulnerability Assessment	Penetration Testing
Identifies and prioritises security weaknesses.	Tests whether vulnerabilities can be exploited.
Usually covers many systems and vulnerabilities.	Focuses on demonstrating the impact of selected weaknesses.
Generally relies on scanning and analysis.	Uses controlled exploitation techniques within an authorised scope.
Produces a list of vulnerabilities and recommendations.	Produces evidence of exploitability, impact, and remediation needs.

Two Common Vulnerability Scanning Tools

1. **Nessus:** Identifies vulnerabilities, misconfigurations, and outdated software.
2. **OpenVAS:** Scans systems and networks for known vulnerabilities.

Conclusion: Vulnerability assessment helps organisations identify security weaknesses before attackers exploit them.

Q7. Vulnerability Scoring (5 Marks)

1. CVE

CVE (Common Vulnerabilities and Exposures) is a system that assigns unique identifiers to publicly known cybersecurity vulnerabilities.

Example: CVE-2021-44228 identifies the Log4Shell vulnerability in Apache Log4j.

2. CVSS

CVSS (Common Vulnerability Scoring System) is a standard used to measure the severity of a vulnerability.

CVSS v3.1 and v4.0 use a score ranging from **0.0 to 10.0**.

CVSS Severity Levels (CVSS v3.1)

Score	Severity
0.0	None
0.1–3.9	Low
4.0–6.9	Medium
7.0–8.9	High
9.0–10.0	Critical

How CVSS Helps Prioritise Vulnerabilities

1. It provides a standard method for comparing vulnerability severity.
2. It helps security teams identify vulnerabilities requiring urgent attention.
3. It considers factors such as exploitability and potential impact.

Why a High CVSS Score Alone Is Not Enough

A high CVSS score does not automatically mean that a vulnerability must always be patched first. Organisations must also consider:

- **Exploit Availability:** Whether attackers are actively exploiting the vulnerability.
- **Asset Importance:** Whether the affected system contains critical business data.
- **Exposure:** Whether the system is accessible from the internet.
- **Business Impact:** How seriously exploitation could affect operations.

Example: A medium-severity vulnerability actively exploited on an internet-facing server may require attention before a critical vulnerability on an isolated test system.

Conclusion: CVSS measures severity, while effective patch prioritisation also considers real-world threat and business risk.

Q8. Threat Data Sources and OSINT (5 Marks)

Threat Data Sources

Threat data sources provide information about cyber threats, attackers, vulnerabilities, and suspicious activities.

Source	Explanation	Example
1. Internal	Data collected within an organisation.	Firewall logs, server logs, and antivirus alerts.
2. External	Information obtained from outside security organisations or services.	Threat reports and security advisories.
3. Open-Source	Publicly accessible threat information.	Public vulnerability databases and security blogs.
4. Commercial	Threat intelligence provided by paid security vendors.	Subscription-based threat intelligence platforms.

Definition of OSINT

Open-Source Intelligence (OSINT) is the process of collecting and analysing information from publicly accessible sources to produce useful intelligence.

Three OSINT Sources or Tools

1. Shodan

- Searches for internet-connected devices and services.
- Helps identify exposed systems and potentially risky services.

2. VirusTotal

- Analyses files, URLs, domains, and IP addresses using multiple security engines.
- Helps investigate suspicious files and indicators of compromise.

3. theHarvester

- Collects publicly available information such as email addresses, domains, and hostnames.
- Helps organisations understand their public-facing information exposure.

Conclusion: Threat data sources and OSINT help security teams identify suspicious activities, understand potential threats, and improve defensive measures.

Q9. Indicators of Compromise (IoCs) (5 Marks)

Definition: Indicators of Compromise (IoCs) are pieces of evidence that suggest a system or network may have been compromised.

Types of IoCs

Category	Explanation	Two Examples
1. Network-Based	Indicators observed in network traffic or connections.	Communication with a known malicious IP address; unusual connections to a suspicious domain.
2. Host-Based	Indicators observed on a computer or operating system.	Unexpected registry changes; suspicious processes running on a system.
3. File-Based	Indicators associated with files.	Known malicious file hash; suspicious executable file found on a computer.

How Security Teams Use IoCs During Incident Response

1. **Detection:** Search network traffic, logs, and endpoints for known IoCs.
2. **Investigation:** Examine the identified systems to determine whether an attack occurred.
3. **Containment:** Isolate affected devices or block malicious IP addresses and domains when appropriate.
4. **Eradication:** Remove malicious files and eliminate the attacker's access.
5. **Recovery and Monitoring:** Restore affected systems and monitor for further suspicious activity.

Example: If a security team detects a connection to a known malicious IP address, it investigates the source device, checks for related malware, and blocks the connection when appropriate.
Conclusion: IoCs help detect attacks, investigate incidents, and prevent further compromise.

Q10. Threat Feeds (5 Marks)
Definition: A threat intelligence feed is a continuously updated source of information about cyber threats, such as malicious IP addresses, suspicious domains, malware hashes, and attacker activity.
Common Threat Feed Formats

1. **CSV (Comma-Separated Values):** Stores threat information in rows and columns.
2. **JSON (JavaScript Object Notation):** Represents threat data in a structured format that software can process.
3. **STIX (Structured Threat Information Expression):** Represents and exchanges structured cyber threat intelligence.
4. **TAXII (Trusted Automated Exchange of Intelligence Information):** Defines methods for exchanging cyber threat intelligence between systems.

STIX and TAXII

- **STIX:** Defines how threat intelligence information is represented and structured.
- **TAXII:** Provides a standard mechanism for exchanging threat intelligence.

Easy to remember: STIX describes the threat information; TAXII helps transport or share it.
Two Advantages of Threat Feeds

1. **Early Threat Detection:** Help security teams identify known malicious IP addresses, domains, and file hashes.
2. **Automated Security:** Can be integrated with security tools such as firewalls, SIEM systems, and intrusion detection systems.

Two Limitations of Threat Feeds

1. **False Positives and Stale Data:** Some indicators may be outdated or incorrectly classified.
2. **Incomplete Coverage:** A feed may not include new, unknown, or highly targeted threats.

Two Examples of Threat Intelligence Feeds
1. AlienVault OTX

- Provides community-contributed threat intelligence.
- Shares information about malicious IP addresses, domains, and other threat indicators.

2. abuse.ch

- Provides threat intelligence related to malware, botnets, and malicious infrastructure.
- Offers resources such as URLhaus for tracking malicious URLs.

Conclusion: Threat feeds provide timely threat information and support automated detection, but their accuracy and relevance must be evaluated before taking action.
